MINOR PROJECT ASSESSMENT

Reconnaissance & Information Gathering — Answer Guide
Topics: Netcraft • Webalizer • Shodan • Subdomain Enumeration • Burp Suite

Important note before submission

This document answers all five tasks in the supplied assessment PDF. Since no authorized target domain, server logs, Shodan export, or lab-application results were supplied, any example values below are illustrative—not real findings. Replace placeholders and example observations with results from your assigned lab, and attach your own screenshots/tool exports. Perform every activity only on systems you own or have explicit permission to test.

Task 1: Passive Reconnaissance with Netcraft

Q1. What is the objective?

To gather passive information about an authorized domain and document its hosting provider, netblock owner, IP address, server location, web-server software, operating system, detected CMS/technologies, and risk rating.

Q2. What steps should be followed?

• Open Netcraft's Site Report service and enter the approved target domain.

• Record the report date and the exact domain searched.

• Copy the hosting provider, netblock owner, IP address, server location, web-server details, operating-system details, and detected technologies exactly as reported.

• Install/use the Netcraft browser extension if required by the assessment, open the approved site, and record the risk rating shown.

• Capture screenshots of the report and extension result; do not expose private or sensitive information in the report.

Q3. What should the summary table contain?

Field	Value to record
Target domain	[authorized-domain.example]
Hosting provider	[as shown by Netcraft]
Netblock owner	[as shown by Netcraft]
IP address	[reported IP address]
Server location	[reported location]
Web server / OS	[reported values; mark unknown if not shown]
CMS / technologies	[detected technologies]
Risk rating	[extension/report result]
Evidence	[screenshot filename and date]

Q4. What could an attacker learn from this data alone?

The information may reveal the hosting provider, approximate infrastructure location, public IP address, web-server family, CMS or framework clues, and technologies that could help an attacker plan further reconnaissance. It does not by itself prove that the site is vulnerable. Version details may be incomplete or outdated, and a risk rating is a signal rather than a complete security assessment.

Q5. Example written observation

“The passive report identified the target’s reported hosting and technology footprint. These details can help an administrator maintain an accurate asset inventory and prioritize updates. The information alone does not establish exploitability; any suspected weakness should be verified only through approved testing.”

Task 2: Web Server Log Analysis with Webalizer

Q1. What is the objective?

To generate traffic statistics from a local/authorized Apache or Nginx access log, identify the busiest IP addresses and requested pages, review HTTP status codes, and flag patterns that may indicate automated scanning.

Q2. What steps should be followed?

• Use a sample access log from the provided VM or a server you administer.

• Configure Webalizer’s input-log path and report output directory; confirm the log format matches the parser.

• Run Webalizer and open the generated HTML report.

• Record top visitor IPs, most requested URLs, request volume over time, and status-code counts.

• Inspect repeated 404 responses, unusually rapid requests, requests for common sensitive paths, and repeated attempts across many URLs.

• Save the HTML report or screenshots and note the time window and log source.

Q3. How can suspicious activity be identified?

A single 404 response is normal. A stronger scanning indicator is one source making many rapid requests to different nonexistent or sensitive paths, such as guessed admin pages, configuration files, or backup files. Compare request rate, URL diversity, status codes, user-agent strings, and normal traffic patterns before drawing a conclusion.

Q4. Example observation (replace with actual log evidence)

Indicator	Illustrative interpretation
One IP has many 404s in a short period	Potential path guessing; review requested paths and rate
Repeated requests to many unrelated URLs	May indicate automated discovery/scanning
Many 200 responses to normal pages	Could be normal browsing; inspect context
Repeated 401/403 responses	Could indicate failed access attempts; not proof of attack
Sudden traffic spike	Could be a crawler, test, event, or attack; correlate with logs

Q5. What is the recommended response?

• Preserve the relevant log lines and timestamps for investigation.

• Check whether the source IP belongs to an approved scanner, monitoring service, or internal test.

• Review application/server configuration and patch any confirmed weakness.

• Apply rate limiting, WAF rules, or temporary blocking only when justified and consistent with operational needs.

• Monitor whether the pattern continues; document the reason for every defensive action.

Example conclusion: “The source should be classified as suspicious only if the log evidence shows a repeated, abnormal pattern. The final report must cite the actual IP, time range, request count, representative paths, and status codes rather than relying on a guess.”

Task 3: Asset Discovery with Shodan

Q1. What is the objective?

To use Shodan's indexed information for an explicitly authorized scope, inventory exposed hosts and services, assess exposure risk, and recommend mitigations.

Q2. What steps should be followed?

• Confirm the exact organization, IP range, or lab host approved by the mentor.

• Search only within that scope, using appropriate filters such as org:, country:, port:, or product: where applicable.

• Export or screenshot the results and record the query used and the search date.

• Build a table of host IP, open port, service/banner, reported location, evidence, and risk notes.

• Cross-check a relevant domain/hosting detail with the Netcraft report where applicable.

• Prioritize unexpected public services, outdated software banners, exposed remote administration, and services that should not be internet-facing.

Q3. What should the exposure table contain?

Host/IP	Port	Service/banner	Location	Risk note	Recommended action
[authorized host]	[port]	[observed banner]	[reported]	[evidence-based risk]	[specific mitigation]
[authorized host]	[port]	[observed banner]	[reported]	[evidence-based risk]	[specific mitigation]

Q4. What makes an exposed service risky?

Risk depends on the service's purpose, whether it must be public, software/version support status, authentication, network restrictions, known vulnerabilities, and the sensitivity of the system. An open port alone is not proof of a vulnerability. For example, public RDP or Telnet may be higher risk if not intentionally exposed or adequately protected.

Q5. How should a risky exposure be mitigated?

• Close unnecessary ports and disable services that are not required.

• Restrict administration services through a VPN, allowlist, or private network.

• Patch supported software and remove default credentials; use strong authentication and MFA where supported.

• Review firewall/security-group rules and monitor service logs.

• Recheck the exposure after remediation and keep evidence of the before/after state.

Example conclusion: "The highest-priority finding is the service that combines unnecessary public exposure with a credible weakness or sensitive function. The report should explain the evidence and business impact, not label a service vulnerable based only on its port number."

Task 4: Subdomain Enumeration

Q1. What is the objective?

To discover subdomains for an authorized domain using at least two methods, merge and deduplicate the results, then verify DNS resolution and HTTP responsiveness.

Q2. What steps should be followed?

• Run one approved enumeration tool (for example, Subfinder, Amass, or Sublist3r) against the authorized domain and save the output.

• Cross-check with a passive Certificate Transparency source such as crt.sh.

• Merge the two lists, normalize names, and remove duplicates.

• Check DNS resolution, then test HTTP/HTTPS response codes for hosts that resolve. Use a conservative request rate.

• Record possible development, test, staging, or forgotten hosts for review; do not attempt to log in or exploit them.

Q3. What commands can be used in an authorized lab?

Example commands—replace example.com with the domain explicitly approved for the assessment:

```
subfinder -d example.com -silent -o subfinder.txt
curl -s 'https://crt.sh/?q=%25.example.com&output;=json' -o crtsh.json
```

After safely extracting and deduplicating names, DNS and HTTP checks can be performed with approved tools such as dnsx/httpx. Confirm each tool's options with its local help output, because flags may differ by version.

Q4. What should the live-subdomain table contain?

Subdomain	Source(s)	DNS result	HTTP status	Observation
[sub.example.com]	[tool + CT]	[resolves / no record]	[200/301/403/404/timeout]	[brief, evidence-based note]
[dev.example.com]	[tool + CT]	[result]	[result]	[review if unexpected]

Q5. How should a forgotten dev/test host be handled?

A development or staging name is only a lead, not proof of a security issue. Confirm ownership and business purpose with the system owner. If it is no longer needed, remove its DNS record and service; if needed, restrict access, remove test data/default credentials, patch it, and prevent unintended public exposure.

Example conclusion: "The consolidated inventory contains the unique names returned by both methods. DNS resolution and HTTP status were checked separately because a subdomain may exist in DNS without hosting a working web application, and a 403/404 response does not necessarily mean the host is offline."

Task 5: Traffic Interception & Analysis with Burp Suite

Q1. What is the objective?

To configure Burp Suite as a local intercepting proxy for a lab application, inspect a login request, replay and modify a request in Repeater, and use a small Intruder Sniper test against a deliberately vulnerable lab input.

Q2. How should Burp be configured?

• Start Burp Suite in the provided lab environment and confirm the proxy listener is bound to 127.0.0.1:8080.

• Configure the test browser to use that proxy. Install Burp's CA certificate only in the lab browser/profile when HTTPS inspection is required.

• Open the authorized lab application and verify that requests appear in Proxy/HTTP history.

• Use only a test account and dummy data; do not capture other people's traffic or real credentials.

Q3. How do Proxy, Repeater, and Intruder work?

Module	Purpose	What to document
Proxy	Intercepts and displays browser requests/responses passing through Burp.	Request method, URL, headers, parameters, response status; redact secrets.
Repeater	Lets the tester manually resend and adjust a captured request.	Which single parameter changed and how the response/status/body changed.
Intruder	Automates controlled variations of selected request positions.	Target input, small lab-only wordlist, response differences, and test limits.

Q4. How do you inspect a login request safely?

• Submit a dummy login on the lab app while interception is enabled.

• Inspect the HTTP method, path, headers, cookies, content type, and body parameter names.

• Send the request to Repeater and change one harmless test parameter at a time.

• Compare the response status, length, redirect, and message. A changed response may show input handling, but does not by itself prove a vulnerability.

• Run Intruder Sniper only against the assigned lab input with a small, non-destructive wordlist and low request volume.

Q5. What should be reported for each module?

Proxy: which request was captured and what fields were present. Repeater: which one parameter was changed and the observable response difference. Intruder: which input position was tested, what small list was used, and whether any responses differed. Include screenshots with passwords, session cookies, tokens, and personal information redacted.

Q6. Example conclusion

“Proxy provided visibility into the browser-to-application HTTP exchange. Repeater made it possible to test one controlled input change and compare responses. Intruder showed how a limited set of values can be sent systematically. These observations describe application behaviour; any security conclusion requires repeatable evidence and confirmation within the lab scope.”

Overall Evaluation Rubric

Criterion	Weight	How to satisfy it
Correct and complete execution	40%	Complete all five tasks within approved scope; retain accurate outputs.
Documentation clarity	25%	Include clear screenshots, commands/queries, dates, and organized tables.
Analysis and security insight	20%	Explain what evidence indicates, uncertainty, impact, and mitigation.
Ethics and reporting discipline	15%	Use authorized targets only; redact secrets; keep evidence confidential.

Final submission checklist

• One consolidated report with all five tasks in the order given.

• Netcraft screenshot/export and summary table.

• Webalizer HTML report/screenshots, suspicious-log analysis, and recommendation.

• Shodan queries/results, exposure table, and mitigation.

• Subdomain tool output + Certificate Transparency results, deduplicated inventory, and live-host status table.

• Burp project/export or sanitized request/response evidence, screenshots, and module observations.

• All example placeholders replaced with actual authorized-lab results; no fabricated findings.

• Sensitive values such as passwords, session cookies, tokens, and personal data removed from screenshots.

End of answer guide. This guide is based on the five tasks and rubric in the supplied assessment PDF. Actual findings depend on the assigned lab target and evidence collected.